SEC-130: CYBER SECURITY

UNIT-I: Basic foundation of Cyber Security

Information Security

- ***Information security*** refers to the set of **practices**, **processes** and **technologies** to protect information from **unauthorized access** and **modification**.
- It is concerned with protecting information in all its forms – digital files, printed documents, spoken conversations etc.

Importance of Information Security

- Protection of sensitive data
- Business continuity
- Legal and regulatory compliance
- Trust and reputation
- Prevention of financial loss
- National security

Attributes of Information Security

- Attributes aka **Security goals** or **Principles** to ensure information stays safe and usable.
- Commonly grouped as the **CIA Triad (Confidentiality, Integrity, Availability)**
- Extended with **Authentication**, **Non-Repudiation** and **Access Control**.

The CIA Triad

- **Confidentiality:** Protecting information from being accessed or disclosed to un-authorised individuals.
- **Integrity:** Ensuring information remains **accurate**, **complete** and **unaltered** by un-authorised actions.
- **Availability:** Ensuring information and systems are accessible by authorised users whenever needed.

Some more attributes

- **Authentication:** Process of verifying the identity of a user, device, or system before granting access.
- **Non-Repudiation:** Assurance that a person cannot later deny having performed an action.
- **Access Control:** Mechanisms that restrict who can view or use resources in a system. Authenticated doesn’t mean authorised.

Threats and Vulnerabilities

- **Threat**
  - Any potential danger or event that could exploit a weakness and cause harm to a system, network or data.
  - It can be a hacker, a virus, a natural disaster, or even human error.
  - Threats exist whether or not a system has exploitable weakness.

- **Vulnerability**
  - Weakness or flaw in a system, application or network that can be exploited by a threat.
  - Example: Outdated software version, weak password policy or unpatched code

Security Attacks

- **A security attack is any deliberate attempt by an unauthorized party to compromise the confidentiality, integrity, or availability of information or a system.**
- **Security attacks are broadly classified into two categories:**
  - ***Passive Attacks***
  - ***Active Attacks***

Security Attacks – Passive Attacks

- **Refers to attacks where the attacker monitors or intercepts data without altering it.**
- The goal is usually to **gather information secretly**, such as eavesdropping on network traffic or monitoring communication patterns.
- Since the data isn't changed, passive attacks are **hard to detect** but can be prevented through practices like ***encryption***.

Security Attacks – Active Attacks

- **Refers to attacks where the attacker actively modifies, disrupts, or damages data or system operations.**
- These are more noticeable since they alter normal behavior — examples include **modifying data in transit**, **injecting malicious code**, or **shutting down a service**.
- Active attacks are harder to prevent entirely but **easier to detect** than passive ones.

Unauthorized Access

- **Unauthorized Access refers to a situation where an individual gains entry to a computer system, network, or data without proper permission.**
- This directly violates the **confidentiality** and **access control** attributes of information security.

Unauthorized Access – Methods

- **Unauthorized access can occur through several methods:**
  - Exploiting weak or stolen passwords.
  - Taking advantage of unpatched software vulnerabilities.
  - Bypassing security controls through technical loopholes.
  - Physical access to systems that should otherwise be restricted.

Unauthorized Access – Consequences & Prevention

- **Consequences** include theft of sensitive data, unauthorized modification of records, and use of the compromised system as a launch point for further attacks.
- **Prevention** typically involves strong authentication (like multi-factor authentication), strict access control policies, and regular monitoring of system logs for suspicious login attempts.

Impersonation

- **Impersonation refers to an attack in which a malicious actor pretends to be a legitimate, trusted user, system, or organization in order to gain unauthorized access or trick a victim into taking a harmful action.**
- This attack primarily targets the **authentication** attribute of information security.

Impersonation – Common forms

- Common forms of impresonation include:
  - **Phishing**: Sending fake emails or messages pretending to be from a trusted source (like a bank) to trick users into revealing credentials.
  - **Spoofing**: Faking an IP address, email address, or website to appear as a legitimate source..

Impersonation – Common forms (contd.)

- **Social engineering**: Manipulating people into breaking normal security procedures by pretending to be someone with authority (e.g., a fake IT technician asking for a password).

Impersonation - Prevention

- Prevention measures include verifying identities through multiple factors, being cautious of unsolicited requests for sensitive information, and using digital certificates to confirm the authenticity of websites and communications.

Denial of Service (DoS)

- **Denial of Service (DoS) refers to an attack that aims to make a system, network, or service unavailable to its legitimate users by overwhelming it with excessive traffic or requests.**

- This attack directly targets the **availability** attribute of information security.

Denial of Service (DoS) - DDoS

- In a **Distributed Denial of Service (DDoS)** attack, multiple compromised systems (often called a ***botnet***) simultaneously flood the target, making the attack much larger and harder to block, since traffic comes from many different sources at once.

Denial of Service (DoS) – Effects & Mitigation

- **Effects** of a successful DoS/DDoS attack include **website downtime**, **loss of business revenue**, and **damage to customer trust**.
- **Mitigation** strategies include **traffic filtering**, **rate limiting**, **using firewalls** and **intrusion detection systems**, and **deploying dedicated DDoS protection services**.

Malicious Software

- Malicious Software, commonly called “***Malware***”, refers to **software intentionally designed to cause damage to a computer, server, network or to gain unauthorized access to a system.**
- It can violate confidentiality, integrity and availability all at once, depending on its purpose.
- The most common types of malware are viruses, worms, and trojan horses.

Malicious Software – ***Viruses***

- A Computer Virus refers to **a malicious program that attaches itself to a legitimate file or program and spreads by inserting copies of itself into other programs when the infected file is executed**.
- **A virus needs a "host"** — it cannot spread on its own; it requires a user to run or share the infected file.

Malicious Software – *Viruses(contd.)*

- Viruses can corrupt or delete data, slow down system performance, or render program unusable.
- It spreads through infected files, email attachments, USB drives, or downloads.

Malicious Software – *Worms*

- A Computer Worm refers to a **self-replicating malicious program that spreads automatically across networks** without needing to attach itself to another program or requiring human action.
- In other words, **a worm does not need a host** file or a user to trigger it — it can spread entirely on its own once it finds a vulnerable system.

Malicious Software – *Worms(contd.)*

- Worms can spread extremely fast, consuming large amounts of bandwidth and system resources.
- They are often used to create backdoors or deliver additional malware to infected systems.

Malicious Software – *Trojan Horses*

- A Trojan Horse refers to **malicious software that disguises itself as a legitimate or useful program to trick users into installing or running it**
- Like the mythological Trojan Horse, it looks harmless (or even helpful) on the outside but carries a hidden malicious payload.
- Trojan horses **do not self-replicate** like viruses or worms.

Malicious Software – *Trojan Horses(contd.)*

- Trojan horses are often used to create backdoors, steal sensitive information, or give attackers remote control of the infected system.
- Some common ways of delivering trojan horses are fake software downloads, malicious email attachments, or deceptive links.

Authentication

- Authentication is **the process by which a system verifies that a user is indeed who they claim to be, prior to granting access to a resource, service, or account**.
- Authentication occurs routinely in everyday computing, such as entering a password to access an email account, scanning a fingerprint to unlock a mobile device, or entering a PIN at an ATM.

Authentication – *vs Identification vs Authorization*

- Authentication is distinct from two related concepts with which it is frequently confused:
  - **Identification** refers to the act of claiming an identity, such as entering a username. This is a statement of identity, not proof of it.
  - **Authorization** occurs after successful authentication and determines the specific privileges and permissions granted to the verified user.

Authentication – *Types*

- **Knowledge-Based Authentication:** It relies on confidential information known only to the legitimate user, such as a password or a personal identification number (PIN). It is sometimes also referred to as password authentication.
- **Possession-Based Authentication:** It relies on a physical item held by the legitimate user, such as an identity card, smart card, security token, or a mobile device receiving a one-time password (OTP).

Authentication – *Types(contd.)*

- **Inherence-Based Authentication**: This category relies on unique physiological or behavioural characteristics of the individual, such as a fingerprint, facial structure, iris pattern, or voice.
- **Location-Based Authentication**:This category relies on the verified physical location of the user, typically determined through GPS data or network information.

Authentication – *Types(contd.)*

- **Multi-Factor Authentication (MFA)**: This refers to the combination of two or more of the above categories to strengthen the verification process.

Password Authentication

- Password Authentication is the **most established** and **widely implemented** method of identity verification.
- A user defines a secret string of characters at the time of account creation and is subsequently required to reproduce it correctly at each login attempt.

Password Authentication – *Prevalency*

- Password authentication remains prevalent for the following reasons:
  - It requires no specialized hardware, resulting in **low implementation cost**.
  - It is a **familiar mechanism** requiring minimal user training.
  - It offers **flexibility**, as credentials can be modified readily in the event of suspected compromise.

Password Authentication – ***Drawback***

- password-based systems are widely regarded as one of the weaker components of information security, primarily because **their effectiveness is contingent upon user behaviour**.
- If the user select passwords that are easily memorable, which correspondingly renders them more susceptible to being guessed or deduced.

Password Vulnerabilities

- Password vulnerability refers to a **weakness in the manner in which passwords are selected, stored, or managed making it exploitable by attackers.**
- Commonly observed weaknesses include:
  - Selection of short or simplistic passwords.
  - Reuse of identical passwords across multiple accounts.
  - Inclusion of easily obtainable personal information, such as a date of birth.
  - Recording or disclosure of passwords to other individuals.
  - Prolonged use of a password without periodic modification.

Password Attacks – *Brute Force Attack*

- **A Brute Force Attack is an attack method in which an attacker systematically attempts every possible combination of characters until the correct password is identified.**
- This method does not rely on inference or probability; it proceeds through all possible combinations in a methodical and exhaustive manner.

Password Attacks – *Brute Force Attack (Contd)*

- **The technique is executed through automated software** capable of generating and testing a substantial number of password combinations within a short period.
- **As password length and character complexity increase, the total number of possible combinations increases correspondingly.**
- The effectiveness is commonly mitigated through mechanisms such as **account lockout after a specified number of unsuccessful attempts**, or the imposition of a **delay between successive login attempts.**

Password Attacks – *Dictionary Attack*

- **A Dictionary Attack is an attack method in which an attacker attempts a predefined list of commonly used words, real words, and previously compromised passwords.**
- The effectiveness of this method arises from the widespread tendency of users to select predictable, easily guessable passwords rather than random character sequences.

Password Attacks – *Dictionary Attack (Contd.)*

- This method is generally more efficient than a brute force attack, as it does not expend resources testing improbable combinations, and instead focuses on credentials with a higher likelihood of success.

Password Attacks – *Brute Force vs Dicitionary Attack*

- A brute force attack tests all possible combinations without exception, whereas a dictionary attack tests only those combinations considered probable.
- Brute force attacks are slower but will eventually succeed given sufficient time, while dictionary attacks are faster but succeed only if the actual password corresponds to a common or predictable entry.

Password Policy

- A Password Policy refers to a **formal set of rules established and enforced by an organization to ensure that user-selected passwords meet a defined standard of strength and are managed securely**.
- The objective is to **minimize the likelihood of passwords being guessed, stolen, or otherwise compromised**.

Password Policy – *Provisions*

- A comprehensive password policy typically includes the following provisions:
  - **Minimum length requirement**
  - **Complexity requirements**
  - **Periodic expiry**
  - **Password history enforcement**
  - **Account lockout mechanisms**
  - **Restrictions on sharing and reuse**

Password Discipline

- **Password discipline refers to the responsible practices that an individual user is expected to observe independently of organizational policy, in order to safeguard their own credentials.**
- **This includes:**
  - Refraining from disclosing passwords to others
  - Avoiding reuse of a single password across multiple accounts
  - Avoiding the use of easily discoverable personal information
  - Promptly changing a password upon any suspicion of compromise

Single Sign-On (SSO)

- **Single Sign-On (SSO) refers to an authentication mechanism that permits a user to authenticate once and subsequently gain access to multiple independent applications or services without the requirement to authenticate separately with each.**
- This approach offers considerable benefit in terms of usability, as **it reduces the number of credentials a user must maintain** and the **frequency with which authentication is required**, thereby also **reducing the incidence of weak, forgotten, or reused passwords**.

Single Sign-On (SSO) – *Kerberos*

- **Kerberos is among the most widely implemented protocols enabling single sign-on.**
- **Kerberos is commonly deployed within institutional and enterprise network environments.**

Single Sign-On (SSO) – *Kerberos - Operation*

1. The user authenticates their identity, typically via a password, to a centrally trusted authority referred to as the **Key Distribution Center (KDC)**.

2. Upon successful verification, the KDC issues the user a time-limited credential known as a ***ticket***.

3. When the user subsequently seeks access to another service on the same network, the previously issued ticket is presented in place of a fresh set of login credentials.

Single Sign-On (SSO) – *Kerberos – Operation (Contd.)*

4. As this ticket is recognized and trusted by all integrated services, and is configured to expire after a defined period, the user is afforded continuous access throughout the session.

Single Sign-On (SSO) – *Kerberos – Advantages*

- The Kerberos protocol avoids the repeated transmission of the user's password across the network, thereby **reducing the risk of interception**.
- It **improves operational efficiency**, as a single successful authentication suffices for the duration of the session.

Biometrics

- **Biometrics refers to the use of unique physiological or behavioural characteristics of an individual to verify identity, as an alternative to knowledge-based credentials (such as passwords) or possession-based credentials (such as identity cards).**
- As such characteristics are intrinsic to the individual, they present considerably **greater difficulty for replication, theft, or transfer** and **cannot be forgotten in the manner of a password**.

Biometrics – ***Types***

- **Fingerprint Recognition**: This technique **relies on the distinctive pattern of ridges and valleys present on an individual's fingertip**.
- **Facial Recognition**: This technique **relies on the distinctive geometric features of an individual's face, including the relative positioning of the eyes, the structure of the nose, and the contour of the jawline**, captured through an imaging device.

Biometrics – *Types (Contd.)*

- **Iris and Retina Recognition:** This technique **relies on the unique patterns present in the coloured portion of the eye (iris) or the arrangement of blood vessels at the rear of the eye (retina)**.
- **Voice Recognition:** This technique **relies on distinctive characteristics of an individual's vocal patterns, including tone, pitch, and speech cadence**.

Biometrics – *Types (Contd.)*

- **Signature Recognition:** This technique **relies on the distinctive manner in which an individual produces their signature**, encompassing not only its visual form but also behavioural attributes such as **writing speed, pressure applied, and pauses during execution**.
- **Hand Geometry Recognition:** This technique **relies on the overall dimensions and structural configuration of an individual's hand, including finger length and palm width.**

Biometrics – *Accuracy Metrics*

- **False Rejection Rate (FRR):** This metric **refers to the rate at which a biometric system incorrectly denies access to a legitimate, authorized user**, erroneously treating them as unrecognized.
- **False Acceptance Rate (FAR):** This metric **refers to the rate at which a biometric system incorrectly grants access to an unauthorized individual**, erroneously treating them as the legitimate user.

Biometrics – *Accuracy Metrics (Contd.)*

- **Crossover Error Rate (CER):** This metric **refers to the point at which the False Rejection Rate and the False Acceptance Rate become numerically equal**, and is employed as a composite measure of overall biometric system accuracy.
  - The Crossover Error Rate represents the precise threshold at which both error types occur with equal frequency
  - **Lower Crossover Error Rate indicates a more accurate and reliable biometric system**

SEC – CyberSecurity WhatsApp Group

